# gRPC

google 做的 RPC 框架

- 可以雙向串流，在 netbird 中 peer 有一條 sync 等待 server 推送，server 隨時可以往裡面寫入
- 有 trailer，他的狀態碼不放 HTTP 狀態碼裡面，要看 body 送完之後的 grpc-status
- 可以多工，多個 RPC 共用一條連線

# CloudFront

有兩條連線

- 使用者到 CloudFront 這段可以 HTTP/2 用 ACM 的憑證
- CloudFront 到 EC2，origin 端，這段憑證跟協定要另外決定

1. cloudfront 會用 Content-Type 來確定傳入的請求是 grpc 還是一般的 http/https 請求
2. 並且Content-Type 是 cloudfront 會原樣轉給 origin 所以從外部到 CloudFront 再到 ec2
3. 但是 grpc 要的是前面講的三個機制，trailers、狀態碼在結尾 trailer（grpc-status）、可以長時間開著的 stream，這三個欄位只有在 HTTP/2 才有
4. 但是 CloudFront 對 origin 預設就是用 HTTP/1.1 所以上述三個要求都不成立所以沒辦法用 grpc
5. 要讓回源那段用 HTTP/2，HTTPS 是在 TLS 握手時用 ALPN 欄位談好，明文 HTTP 沒有這個欄位。明文的 HTTP/2（h2c）要靠 `Upgrade` header 升級，但 CloudFront 不會把它送給 origin。所以 gRPC 要經過 CloudFront，回源只能用 HTTPS
6. 實測 CloudFront 在建立時就擋掉「HTTP 回源加 gRPC」，錯誤訊息直接寫 origin 要支援 HTTPS。不開 gRPC 選項硬用 HTTP/1.1 回源，gRPC 請求會壞掉，origin 回 404，同一條路的 REST 正常。所以機器上一定要有一張公開受信任的憑證，用 Let's Encrypt 免費簽。實測紀錄在 `5tmate/NETBIRD_CLOUDFRONT_GRPC_TEST.md`

# 今天做了什麼

早上決定拿掉 traefik，改成兩條 CloudFront。整理登入要怎麼保護、`pulumi up`，實測 gRPC 能不能走 CloudFront、修好登入。

## 拿掉 traefik

- netbird-server 自己就能做 TLS，設定 `server.tls.letsencrypt.awsRoute53`，用 Route 53 做 DNS-01 簽 Let's Encrypt，不需要讓 Let's Encrypt 連進機器驗證
- 一個 443 就能跑 gRPC、`/api`、`/oauth2`、relay，netbird-server 自己看 Content-Type 跟路徑分流，不需要 traefik

## 登入要怎麼保護

一開始想藏 dashboard，後來發現擋錯東西了。dashboard 只是一包公開的靜態 JS，真正收密碼的是 netbird-server 裡的 `/oauth2`（Dex）。peer 的 gRPC 跟登入都在同一個 443，加密之後從外面看不出差別，安全群組、IP 白名單都分不開，只有 CloudFront 解密之後能照路徑分。

| 方案 | 結果 |
| --- | --- |
| Cognito、Google 登入 | 可以而且免費，但不想依賴外部帳號 |

| 方案 | 結果 |
| --- | --- |
| 自架 PocketID，用 passkey | 可以，但多一個容器跟資料庫，太複雜 |
| 安全群組只放行 peer 的 IP | 不行，擋 443 會連 gRPC 一起擋，peer 換了網路就連不回來 |
| Lambda 把 peer 的公網 IP 同步到 CloudFront KVS | 可以，錢也很少，但零件多，辦公室、手機網路很多人共用一個 IP，等於沒擋 |
| TOTP | 不開，每個人登入都要多做一次 |
| `/oauth2`、`/api` 在公網一律回 404，管理員從 mesh 裡面連 | 中午的決定，下午改掉 |

### 下午改的決定

- 公司人很多，不可能一個一個發 setup key，所以 netbird 也走 CloudFront，先對外開放，之後再說
- 想在 CloudFront 用 ACM 憑證、明文回源，這樣就不用 Let's Encrypt。實測 gRPC 不行（上面第 5、6 點），dashboard 跟 REST 可以
- 想過在機器上加 nginx 接 CloudFront，但回源用什麼協定是 CloudFront 決定的，nginx 要收 gRPC 一樣要有憑證，等於把 traefik 換個名字
- 在 CloudWatch 看 dashboard 的 nginx access log，CloudFront 打進來的每一行都是 `HTTP/1.1`，瀏覽器到 CloudFront 那段則是 HTTP/2
- `/oauth2` 只有瀏覽器會用，可以走 CloudFront，peer 用的 gRPC 不行

## 小結

gRPC 走 CloudFront 只能 HTTPS 回源，機器要有憑證。拿掉 traefik，netbird-server 自己簽 Let's Encrypt。登入該擋 /oauth2，先對外開放。

## 參考資料

- Using gRPC with CloudFront distributions - Amazon CloudFront(gRPC 只支援端到端 HTTPS)
- Request and response behavior for custom origins - Amazon CloudFront(`Upgrade` header 會被拿掉)
- RFC 9113: HTTP/2(h2c 的 Upgrade 已經廢棄)
- RFC 7301: TLS Application-Layer Protocol Negotiation Extension(ALPN)
- gRPC over HTTP2 - grpc/grpc(trailer 跟 `grpc-status`)
- Challenge Types - Let's Encrypt(DNS-01)
- Self-Hosted Deployment Configuration Files Reference - NetBird Docs
- Documentation - Dex
- Amazon CloudFront KeyValueStore - Amazon CloudFront